Admin Panel and RBAC: Implementation Status

As of 28 Oct 2026. Branch: feature/admin-panel (local work, not yet committed).

Done

BACKEND (FASTAPI, BACKEND/)

- Login with email and password, bcrypt hashes, JWT access tokens (60 minutes).
- Roles sysAdmin, admin and user with a fixed permission map. Every admin route checks its permission on the server.
- Company isolation: one helper scopes every query to the user's company. Another company's records return 404.
- Admin APIs: companies (sysAdmin), users (admin for own company, sysAdmin for all), audit log.
- Rules: a company keeps at least one active admin, no self role or status change, only a sysAdmin creates a sysAdmin, no new users in an inactive company.
- Audit log: written in the same transaction as each change, append-only. Includes failed logins.
- Signup: creates a new company and its first admin.
- Password reset: forgot-password and reset-password. Single-use token, 15 minutes, same reply for unknown emails. Reset tokens cannot be used as login tokens.
- First sysAdmin created at startup from SYSADMIN_EMAIL and SYSADMIN_PASSWORD when no users exist.

ADMIN UI (REACT, ADMIN-UI/)

- Sign in, create company, forgot password and set new password screens.
- Role-aware navigation: Users, Companies (sysAdmin only), Audit log. Users with the user role see a no-access message.

- Users page: add, change role, deactivate and restore. Controls that are not allowed for a row are hidden.
- Companies page: add, deactivate and restore.
- Audit log page with an action filter.

DOCUMENTS (DOCS/)

- Approved plan, API endpoint list for testers with 31 test cases, and this status note.

Verified

- 17 automated backend tests pass: 401 and 403 checks, cross-company access, sysAdmin access, audit rows, admin rules, signup, single-use password reset.
- Live test in Chrome: signup, forgot password, reset link, sign in with the new password, audit log entries, reused reset link refused.

Not done yet

- Live click-through of the Users, Companies and Audit pages as each of the three roles.
- Password reset email: the link is printed in the backend log until a mail server is set up.
- Refresh tokens, database migrations (tables are created at startup), CORS and production settings.
- Connecting the graph routes to the auth and company-scope helpers. The graph code is not in this repo.
- Commit, push and PR. Directive checks run when you ask for them.

Open decision

Signup is open to anyone. Decide whether it stays open, becomes invite-only, or is limited.

CONFIDENTIAL